# Information Security Policy

**Effective Date:**
October 05, 2026

**Category:**
Security

**Scheduled Review:**
October 2027

## 1. Authority

*Executive Order 2016-06, Enterprise Information Technology Governance*

## 2. Document Control

This document replaces, in its entirety, the *Information Security Policy*, dated January 6, 2025.

## 3. Purpose

This policy establishes the Commonwealth's enterprise information security program to protect the confidentiality, integrity, and availability of Commonwealth IT resources and data in accordance with applicable laws, regulations, and recognized security standards.

## 4. Scope

This policy applies to all offices, departments, boards, commissions, and councils under the Governor's jurisdiction and any other entity connecting to the Commonwealth Network (hereinafter referred to as "agencies").

## 5. Policy

For definitions of terms found within this document, refer to the *IT Policy Glossary*.

### 5.1 Information Security Governance

The Office of Administration, Office for Information Technology (OA/OIT) Enterprise Information Security Office (EISO) shall establish, maintain, and continuously improve the Commonwealth's enterprise information security program.

The Commonwealth's information security program shall align with recognized security standards and frameworks, including applicable National Institute of Standards and Technology (NIST) publications and other industry-recognized cybersecurity practices, as appropriate.

Information security requirements and controls shall be selected, implemented, and maintained using a risk-based approach that considers business objectives, legal and regulatory requirements, data sensitivity, system criticality, threats, vulnerabilities, and potential impacts to Commonwealth operations.

Agencies shall comply with applicable Commonwealth information security policies and standards issued by OA/OIT.

Agencies are responsible for implementing applicable security requirements, maintaining compliance with Commonwealth information security policies and standards, and ensuring that agency-managed systems, services, and information are protected commensurate with risk.

In the absence of a specific Commonwealth policy or standard addressing a particular security requirement, agencies shall implement appropriate security measures based on recognized industry best practices and applicable NIST guidance until Commonwealth requirements are established.

Agencies shall protect Commonwealth IT resources and data throughout their lifecycle, including planning, acquisition, development, implementation, operation, maintenance, and disposal.

Agencies shall implement appropriate administrative, technical, and physical safeguards to protect Commonwealth IT resources and data from unauthorized access, use, disclosure, disruption, modification, or destruction.

Agencies shall take timely corrective action to address identified noncompliance, security findings, vulnerabilities, audit findings, control deficiencies, and risks.

### 5.2 Supporting Information Security Policies, Standards, Procedures, and Guidelines

This policy establishes the high-level governance requirements for the Commonwealth's enterprise information security program. In addition to this policy, OA/OIT maintains several other security related policies and standards that collectively define the Commonwealth's information security requirements. Agencies shall comply with all applicable Commonwealth IT policies and standards.

### 5.3 Compliance and Enforcement

Agencies shall comply with this policy and supporting information security standards and procedures.

Agencies shall follow the enterprise IT policy exception process when an exception to applicable policy or standard is required.

Appropriate action may be taken when non-compliance with Commonwealth policies or Management Directives results in, or is suspected of resulting in, loss, damage, or unauthorized disclosure of information.

## 6. Contact

Questions or comments may be directed via email to OA, IT Policy.

## 7. Exception from Policy

In the event an agency chooses to seek an exception from this policy, a request for a policy exception shall be submitted via the IT policy exception process. Refer to *IT Policy Governance Policy* for guidance.

## 8. Revision History

This chart contains a history of this publication's revisions. Redline documents outline the revisions and are available to Commonwealth users only during the drafting process.

| Version | Date | Purpose of Revision |
|---|---|---|
| Original | 01/06/2025 | Base Document |
| Revision | 10/05/2026 | Policy rewritten in its entirety<br>Content moved from policy to applicable standards documents |